INCIDENT REPORT

Security Log Investigation — NoteShare Auth Service

Date: 2024-03-15 | Analyst: SOC Lab | Classification: INTERNAL

1. Executive Summary

On 2024-03-15, analysis of 465 normalised authentication log events (104 failures, 361 successes) revealed a coordinated, multi-stage attack against the NoteShare student notes platform. Three attacker IPs from the RFC 5737 documentation range were identified. The attack progressed from an automated brute-force campaign that successfully compromised the account of a regular user (jsmith), pivoted to a password-spray campaign targeting 15 distinct accounts, and culminated in privileged access by admin_user from an IP address never previously associated with that account during off-hours. No data exfiltration can be confirmed from log evidence alone, but the administrator account access is treated as a high-severity incident requiring immediate response.

KEY METRICS

- Total clean events analysed: 465
- Failure events: 104
- Success events: 361
- Brute-force incidents: 1
- Password-spray incidents: 1
- Unusual-access alerts: 9
- Attacker IPs: 192.0.2.10, 198.51.100.50, 198.51.100.51
- Victim account: jsmith
- Privileged account at risk: admin_user

2. Scope and Method

The investigation was performed entirely on a synthetic authentication log CSV (auth_log.csv) generated with documentation-range IP addresses and fictional accounts. No external systems were contacted. The analysis pipeline was implemented in Python using pandas for data manipulation and matplotlib for visualisations. Raw data quality issues were resolved before detection: fully empty rows were removed, timestamps were parsed to timezone-aware UTC, usernames were stripped and lowercased, IP addresses were validated against IPv4 format, result values were standardised to SUCCESS / FAILURE, and duplicate rows were eliminated. Three documented detection rules were then applied (see Section 3).

3. Detection Rules and Findings

Rule 1 — Brute Force

Threshold: ≥ 10 login failures from one IP against one account within a 60-minute rolling window. Rationale: 10 failures per hour is well above normal password-typo rates (typically 1–3). A subsequent SUCCESS from the same IP is flagged as likely account compromise. False-positive risk: shared NAT/proxy for a large organisation.

Rule 2 — Password Spraying

Threshold: One IP produces failures against ≥ 8 distinct accounts within 60 minutes, with ≤ 3 attempts per account. Rationale: 8 distinct targets from one IP is a clear spray signal; the low per-account count distinguishes spraying from brute force. False-positive risk: IT helpdesk resetting many accounts simultaneously.

Rule 3 — Unusual Access

Three sub-rules: (a) Off-hours privileged login — a privileged account (admin, root, sysadmin) authenticates between 00:00 and 05:59 UTC. (b) New IP for privileged account — a privileged account succeeds from an IP never seen before for that user. (c) Success after failure streak — ≥ 5 consecutive failures then success on the same account. False-positive risk: users in different time zones; travelling admins.

4. Alert Summary Table

Rule	Account / Scope	Attacker IP	Count	First (UTC)	Last (UTC)
Brute Force	jsmith	192.0.2.10	25	2024-03-15 02:00	2024-03-15 02:29
Password Spraying	15 accounts	198.51.100.50	20	2024-03-15 03:00	2024-03-15 03:42
Off-hours Priv. Login	admin_user	198.51.100.51	1	2024-03-15 03:50	2024-03-15 03:50
New IP Priv. Account	admin_user	198.51.100.51	1	2024-03-15 03:50	2024-03-15 03:50
Success After Streak	jsmith	192.0.2.10	25	2024-03-15 02:35	2024-03-15 02:35

** Full findings exported to findings.csv (11 total alert rows)*

5. Incident Timeline and Recommendations

5. Incident Timeline (UTC)

Time	Label	Description
02:00	EVIDENCE	First failure — jsmith vs 192.0.2.10. Brute-force campaign begins.
02:00–02:29	EVIDENCE	25 failures against jsmith from 192.0.2.10 in 30 min (threshold: 10).
02:35	EVIDENCE	jsmith authenticates successfully — password likely compromised.
02:35–03:00	ASSUMPTION	Attacker pauses ~25 min. (Inferred from timestamp gap in log.)
03:00	EVIDENCE	Password spray begins — 198.51.100.50 targets 15 accounts.
03:00–03:42	EVIDENCE	20 failures across 15 accounts in 42 min from 198.51.100.50.
03:50	EVIDENCE	admin_user SUCCESS from new IP 198.51.100.51 — off-hours.
03:50	ASSUMPTION	Possible compromised admin credential or insider. No prior log activity from this IP.
08:00+	EVIDENCE	Normal business traffic resumes (465 clean events, mostly SUCCESS).

EVIDENCE = directly observed in the log data. ASSUMPTION = inferred from evidence with stated reasoning.

6. Recommended Actions

1. Account lockout — Immediately lock jsmith and admin_user pending password reset and investigation. Enforce lockout after 10 consecutive failures going forward.

2. Password reset — Force password resets for all accounts targeted by the spray (15 accounts from 198.51.100.50) and jsmith.

3. MFA enforcement — Require multi-factor authentication for all privileged accounts (admin_user, sysadmin, root_admin) and for any account that authenticates from a new IP.

4. IP blocking — Block 192.0.2.10, 198.51.100.50, and 198.51.100.51 at the perimeter firewall and Nginx allow-list immediately.

5. Rate limiting — Configure Nginx or the Express application layer to limit login attempts to 5 per minute per IP, with exponential back-off.

6. Alerting — Add real-time SIEM rules for brute-force (≥10 failures/60 min) and spray (≥8 accounts/60 min from one IP) with automated incident ticketing.

7. Limitations

• The log covers only authentication events; lateral movement, file access, and network-level activity are not visible.

• The in-memory session store used by the lab (express-session) does not persist session tokens across restarts; a production deployment should use a durable store.

• IP geolocation was not performed; the documentation-range IPs are not routable and cannot be attributed to real networks.

• The analysis is based entirely on a synthetic dataset; production logs may exhibit different patterns and require threshold tuning.